PINNACLE LENDING SOLUTIONS

Information Security GRC Assessment — Executive Summary

Prepared by: Marcus Albright, GRC Risk Analyst | June 2026 | Classification: Internal

Assessment Purpose & Scope

This executive summary presents the findings of a comprehensive information security GRC assessment conducted for Pinnacle Lending Solutions, a residential mortgage lender subject to GLBA Safeguards Rule, CFPB data protection standards, RESPA, and TILA compliance obligations. The assessment evaluated 15 identified risks and 20 control areas against the NIST Cybersecurity Framework (CSF) 2.0 and ISO/IEC 27001:2022, identifying critical gaps and prioritizing remediation.

Risk Assessment Summary

Risk Level	Count	% of Total	Primary Risk Areas
Critical	1	7%	Unauthorized PII access — no MFA on LOS/CRM
High	8	53%	No WISP, IR Plan, BCP, SIEM; access control gaps; ransomware exposure
Medium	6	40%	Network segmentation, phishing training, password management, cloud config
Low	0	0%	—
TOTAL	**15**	**100%**	

Top Risk Findings

Risk ID	Level	Risk Description	Score	Recommended Action
R-001	CRITICAL	Unauthorized PII Access — LOS/CRM	20/25	Implement MFA; quarterly access reviews; PII access logging
R-002	HIGH	No GLBA Written Info Security Program (WISP)	25/25	Draft and ratify WISP; schedule annual risk assessment
R-007	HIGH	No Documented Incident Response Plan	15/25	Develop IR Plan; conduct annual tabletop exercise
R-010	HIGH	Ransomware exposure — backups untested	10/25	Implement 3-2-1 backup strategy; test quarterly; document BCP
R-013	HIGH	No SIEM — security events undetected	12/25	Deploy Wazuh or Splunk; aggregate all critical system logs
R-006	HIGH	Terminated employees retain system access	10/25	24-hr deprovisioning SLA; automate offboarding; audit trail

Controls Maturity Summary

Domain	Controls Assessed	Current Maturity	Target	Priority
Identity & Access Mgmt	2	1 - Initial	3 - Managed	CRITICAL
Data Protection	2	2 - Partial	3 - Managed	HIGH
Security Monitoring	2	1 - Initial	3 - Managed	HIGH
Incident Response	2	1 - Initial	3 - Managed	HIGH
Vulnerability Mgmt	2	1 - Initial	3 - Managed	HIGH
Business Continuity	2	1 - Initial	3 - Managed	HIGH
Third-Party Risk	2	1 - Initial	2 - Partial	MEDIUM

Security Training	1	1 - Initial	3 - Managed	MEDIUM
Access Control	2	1 - Initial	3 - Managed	HIGH
Compliance & Docs	2	0 - Absent	3 - Managed	CRITICAL

Remediation Roadmap

Phase	Timeline	Key Actions	Risk Reduction
Phase 1 Foundation	0–3 Months	Designate CISO · Draft WISP · Conduct risk assessment · Implement MFA · Develop IR Plan · Access review process	Critical → High
Phase 2 Detection	3–6 Months	Deploy SIEM (Wazuh/Splunk) · Enforce endpoint encryption · Launch phishing simulations · Vulnerability scanning	High → Medium
Phase 3 Maturity	6–12 Months	PAM solution · Network segmentation · 3-2-1 backup + BCP · Annual penetration test · Vendor risk program	High → Medium